

ACTIVE DIRECTORY SECURITY AUDIT

Protocol Poisoning & Credential Interception

LEAD AUDITOR

TARGET INFRASTRUCTURE

ATTACK VECTOR

Solomon Waikumi Hospital Internal Network LLMNR / NBT-NS Spoofing

EXECUTIVE SUMMARY

This security audit focused on evaluating the vulnerability of internal network infrastructure to Link-Local Multicast Name Resolution (LLMNR) and NetBIOS Name Service (NBT-NS) poisoning. Using the developed script `NBT_final.py`, we successfully demonstrated the ability to intercept name resolution requests and redirect authentication attempts to an auditor-controlled listener, resulting in the capture of NTLM hashes.

TECHNICAL METHODOLOGY

The script leverages the **Scapy** library to perform packet sniffing and construction.

- **Sniffing:** Monitors UDP port 137 (NBT-NS) and UDP port 5355 (LLMNR) for broadcast name queries.
- **Spoofing:** Upon detection of a QUERY payload, the script constructs a spoofed IP/UDP packet response to the victim.
- **Logging:** Intercepted data is appended to `hospital_hashes.txt` for offline cryptographic analysis.

CODE IMPLEMENTATION SNIPPET

```
def send_spoofed_response(packet):  
    response_packet = scapy.IP(dst=packet[scapy.IP].src) / \  
        scapy.UDP(dport=packet[scapy.UDP].sport) / \  
        scapy.Raw(load="FAKE_RESPONSE")  
    scapy.send(response_packet, verbose=False)
```

SECURITY IMPACT & RECOMMENDATIONS

Impact: High. Capturing NTLM hashes allows attackers to perform offline brute-force attacks or "Pass-the-Hash" maneuvers to gain unauthorized access to hospital systems and sensitive patient data.

Recommendations:

- Disable LLMNR and NetBIOS via Group Policy Objects (GPO) across the domain.
- Implement **SMB Signing** to prevent relay attacks.
- Enforce **Multi-Factor Authentication (MFA)** to mitigate the risk of compromised credentials.